

SIMATS ENGINEERING

ASSESSMENT TOOL 3 – CASE STUDY

Course Code: ITA14 Course Name: Ethical Hacking

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)

Assessment Tool Weightage: 35% Total Marks: 100

Name: SHAM S.

Register No: 192325076

Question 1: Apache Web Server Attack – E-commerce Case

1. Possible Attack Vectors

- Outdated Apache version: Known CVEs (e.g., missing security patches) allow remote exploitation, RCE, or DoS.
- Directory/path traversal: Suspicious requests to hidden directories indicate attempts to access admin panels, backup files, or configuration files (e.g., /admin, /.git, /backup.zip).
- Input validation failure: Malicious scripts injected into input fields point to Cross-Site Scripting (XSS) and possibly SQL Injection, since customer transaction data was manipulated.
- Absence of a Web Application Firewall (WAF): No filtering layer to block malicious payloads before they reach the application.
- Weak session/authentication handling enabling unauthorized transactions and account takeover.

2. Reconnaissance Phase (Kali Linux)

- whois and nslookup / dig – gather domain registration and DNS information.
- theHarvester – collect emails, subdomains, and employee details for social engineering context.
- Nmap (nmap -sV -sC -p- target) – identify open ports, running services, and the exact Apache version/banner.
- Nikto – automated web server scanner to flag outdated software, dangerous files, and misconfigurations.
- dirb / gobuster – brute-force hidden directories and files referenced in the suspicious log entries.

3. Vulnerability Scanning

- OpenVAS / Nessus (via Kali) – scan for known CVEs matching the identified Apache version.
- WPScan (if CMS-based) – detect vulnerable plugins/themes.
- Nikto – cross-check for outdated modules, default files, and misconfigured headers (missing X-FrameOptions, CSP, etc.).
- Burp Suite Scanner – crawl the application and flag injection points in forms and parameters.

4. Exploitation (Controlled/Authorized Testing)

- Metasploit Framework – search and use exploit modules matching the Apache CVE identified during scanning.
- SQLmap – test identified input fields for SQL injection to confirm data extraction risk.

- Manual payload testing in Burp Suite Repeater – confirm XSS execution in vulnerable input fields.
- All exploitation must be performed strictly within an authorized penetration-testing scope with documented consent.

5. Layered Defense Strategy

Server Hardening:

- Patch and update Apache to the latest stable, supported version immediately.
- Disable directory listing and remove/rename default and backup files.
- Run the web server with least-privilege service accounts and disable unused modules.

Secure Coding Practices:

- Implement strict input validation and parameterized queries/prepared statements to prevent injection.
- Apply output encoding to neutralize script injection in rendered pages.
- Enforce secure session management (HttpOnly, Secure, SameSite cookies; session timeout; token regeneration).

Network-Level Protections:

- Deploy a Web Application Firewall (WAF) such as ModSecurity to filter malicious HTTP requests.
- Implement an Intrusion Detection/Prevention System (IDS/IPS) and centralized log monitoring/SIEM.
- Enforce HTTPS/TLS, rate limiting, and regular vulnerability assessments/penetration tests.

Question 2: SQL Injection & XSS in a Financial Web Application

1. How the Vulnerabilities Are Exploited

- SQL Injection: Unsanitized user input in login or search fields is concatenated directly into SQL queries, allowing attackers to inject statements (e.g., ' OR '1'=1) to bypass authentication or extract database contents. Verbose error messages further reveal table/column names, aiding exploitation.
- XSS: Unsanitized input reflected or stored in web pages allows attackers to inject JavaScript, which executes in other users' browsers to steal session cookies, redirect users, or perform actions on their behalf.

2. Step-by-Step Methodology Using Kali Linux Tools

- Step 1 – Mapping: Use Burp Suite (Proxy + Spider) to intercept traffic and map all input points (login form, search, transaction fields).
- Step 2 – Manual Probing: In Burp Repeater, submit test payloads (e.g., ' or 1=1--, <script>alert(1)</script>) to observe application responses and error messages.
- Step 3 – Automated SQLi Testing: Run SQLmap against identified parameters (sqlmap -u "URL" -data="params" --dbs) to confirm injectability and enumerate databases/tables.
- Step 4 – Automated XSS Testing: Use Burp Suite Scanner / XSSStrike to fuzz input fields and confirm reflected and stored XSS.
- Step 5 – Validation: Confirm findings with proof-of-concept payloads that demonstrate impact without causing damage (e.g., extracting a single non-sensitive record, harmless alert box).

-

Step 6 – Documentation: Record affected endpoints, payloads used, and evidence (screenshots/response bodies) in the audit report.

3. Impact on the CIA Triad

- Confidentiality: SQL injection can expose sensitive customer and financial data (account numbers, personal details).
- Integrity: Attackers can modify or delete database records (e.g., transaction tampering) and inject unauthorized scripts that alter page content.
- Availability: Destructive SQL statements or resource-intensive queries can crash the database or degrade application performance, causing denial of service.

4. Mitigation Strategies

- Input Validation: Enforce strict whitelisting/allow-list validation on all user-supplied data.
- Parameterized Queries/ORM: Use prepared statements to eliminate SQL injection at the queryconstruction level.
- Output Encoding: Encode data before rendering it in HTML/JS context to neutralize XSS payloads.
- Secure Session Handling: Use HttpOnly and Secure cookie flags, short session lifetimes, and CSRF tokens.
- Security Controls: Deploy a WAF, implement Content Security Policy (CSP) headers, disable verbose error messages in production, and conduct regular code reviews and penetration tests.

Question 3: Evil Twin Attack on Corporate WPA2-PSK Wi-Fi

1. How the Evil Twin Attack Was Executed

- The attacker set up a rogue access point broadcasting the same SSID as the official corporate network, often with a stronger signal.
- Employee devices, configured to auto-connect to known SSIDs, connected to the rogue AP instead of the legitimate one.
- The attacker may have sent deauthentication frames to disconnect users from the genuine AP, forcing reconnection to the rogue AP.
- Once connected, the attacker positioned themselves as a man-in-the-middle, capturing login credentials (e.g., via a fake captive portal) and intercepting/manipulating traffic (MITM).

2. Detection and Analysis Using Kali Linux Tools

- Airodump-ng – scan for all nearby access points and detect duplicate SSIDs with different BSSIDs/MAC addresses, a strong indicator of an Evil Twin.
- Aircrack-ng suite (airmon-ng, aireplay-ng) – place the wireless adapter in monitor mode and analyze deauthentication frame patterns.
- Wireshark – capture and inspect wireless traffic (802.11 frames) for anomalies such as duplicate BSSIDs, unusual beacon intervals, or unencrypted captive-portal traffic.
- Kismet – passively detect rogue access points and alert on SSID spoofing.

-

3. Weaknesses in the Existing Configuration

Reliance on SSID-based trust alone, without validating the access point's identity (BSSID/certificate).

- WPA2-PSK uses a single shared passphrase, so a leaked or weak passphrase compromises the whole network and doesn't provide per-user accountability.
- No wireless intrusion detection system (WIDS) to flag rogue APs or abnormal deauthentication traffic.
- Lack of employee awareness about verifying network authenticity before entering credentials.

4. Countermeasures

- Migrate to WPA3-Enterprise or WPA2/3-Enterprise (802.1X) with individual user authentication via a RADIUS server, removing the shared-passphrase risk.
- Deploy a Wireless Intrusion Detection/Prevention System (WIDS/WIPS) to detect and automatically contain rogue access points.
- Enable Protected Management Frames (PMF/802.11w) to prevent forged deauthentication attacks.
- Conduct regular wireless site surveys/audits to identify unauthorized APs.
- Run user-awareness training so employees verify network certificates/portals and report suspicious login prompts.

Question 4: Full Penetration Test – Wi-Fi to Web Application Attack Chain

1. Attack Chain Overview

The attack progresses in four connected phases: Wireless Reconnaissance → Wireless Exploitation (Wi-Fi Access) → Web Application Reconnaissance/Scanning → Web Application Exploitation & Privilege Escalation.

2. Phase-by-Phase Analysis with Kali Linux Tools

Phase 1 – Wireless Reconnaissance:

- Airodump-ng identifies the target SSID, BSSID, channel, and connected clients.

Phase 2 – Wireless Exploitation:

- Aircrack-ng / Hashcat – capture the WPA2 4-way handshake and crack the weak Wi-Fi password using a wordlist/dictionary attack.
- Once cracked, the attacker joins the internal network, gaining a foothold.

Phase 3 – Internal Network & Web Application Reconnaissance:

- Nmap – scan the internal subnet to discover the employee management system's host and open ports.
- Nikto / Burp Suite – enumerate the web application's structure, technologies, and input points.

Phase 4 – Exploitation & Privilege Escalation:

- Hydra – brute-force weak authentication on the login page due to weak/no lockout policy.
- SQLmap / Burp Suite – exploit input validation or session management flaws to access or modify records beyond the attacker's authorization level (e.g., manipulating role/session parameters for privilege escalation).
- Metasploit – leverage any further application or OS-level vulnerabilities to gain administrative access.

•

3. Comprehensive Security Framework (Defense-in-Depth)

Wireless Layer:

Enforce strong, complex Wi-Fi passphrases or move to 802.1X/WPA3-Enterprise authentication; segment guest and corporate Wi-Fi with VLANs.

Network Layer:

- Implement network segmentation/firewalls between Wi-Fi access and sensitive internal systems; use IDS/IPS to monitor lateral movement.

Application Layer:

- Enforce strong authentication (MFA), account lockout policies, secure session management, input validation, and role-based access control (RBAC) with server-side authorization checks.

Governance Layer:

- Conduct regular penetration testing, patch management, security awareness training, and continuous log monitoring/SIEM integration.

Question 5: Deauthentication Attacks Disrupting Campus Wi-Fi

1. How Deauthentication Attacks Work

The IEEE 802.11 management frame protocol was originally designed without encryption or authentication for control/management frames (deauth and disassociation frames). This allows an attacker to spoof the source MAC address of the access point (or client) and send forged deauthentication frames. Client devices trust these frames and immediately disconnect, believing the request came from the legitimate AP. By continuously sending such frames using automated tools, the attacker keeps forcing users offline, resulting in a persistent Denial of Service (DoS).

2. Simulating and Analyzing the Attack in Kali Linux (Controlled Lab)

- Airmmon-ng – enable monitor mode on a compatible wireless adapter.
- Airodump-ng – identify the target BSSID/channel and connected client MAC addresses in the authorized lab environment.
- Aireplay-ng (aireplay-ng --deauth) – send controlled deauthentication frames to simulate the attack for analysis purposes only.
- Wireshark – capture and filter 802.11 management frames (`wlan.fc.type_subtype == 0x0c`) to analyze the volume, frequency, and source of deauth frames.
- MDK4 – a Kali tool that can flood-test deauthentication scenarios in a controlled lab to study its impact on AP/client behaviour.

3. Impact on Availability and Productivity

- Repeated disconnections prevent students/staff from accessing online resources, e-learning platforms, and cloud services.
- Network instability reduces trust in the infrastructure and increases IT helpdesk workload.
- Persistent DoS during peak hours (e.g., exam or class times) directly disrupts academic activities and productivity.

-

4. Mitigation Strategies

- Enable 802.11w (Protected Management Frames/PMF) so management frames, including deauth/disassoc, are cryptographically authenticated and cannot be spoofed.
Upgrade to WPA3, which mandates PMF and offers stronger protection against such frame-spoofing attacks.
- Deploy a Wireless Intrusion Detection System (WIDS) to detect abnormal volumes of deauth frames and alert administrators in real time.
- Segment and monitor the network with centralized wireless controllers that can flag and locate rogue devices sending deauth floods.
- Educate network administrators to regularly audit wireless logs and maintain updated firmware on access points.

Code of Conduct

I S. AJAY(Reg No: 192421237) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: _____

Rubrics for Calculation

Criteria	Weight age	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Case	25	Thorough understanding; clearly identifies all key issues	Good understanding with most issues identified	Basic understanding; some issues missed	Poor understanding; problem not identified correctly
Application of Concepts	25	Effectively applies relevant concepts to analyze the case deeply	Applies appropriate concepts with minor gaps	Limited application of concepts	Fails to apply relevant concepts
Analysis	20	In-depth analysis with strong reasoning and insights	Good analysis with logical reasoning	Basic analysis with limited depth	Weak or no analysis; lacks reasoning
Solution Design	20	Innovative, feasible solutions with strong justification	Logical solutions with adequate justification	Basic solutions with weak justification	Incorrect or no solution provided
Clarity	10	Clear, wellstructured, and easy to understand	Organized and understandable presentation	Somewhat unclear or disorganized	Unclear, poorly structured presentation